

ACME Global Security Standard v3.0

Confidential - Internal Use Only

Generated by Gemini Reasoning Engine

1.0 Identity & Access Management (IAM)

1.0 Identity & Access Management (IAM)

1.1 Purpose

The purpose of this Identity and Access Management (IAM) policy is to establish the framework and mandatory controls for creating, managing, and securing digital identities and their access to company information systems, data, and infrastructure. This policy aims to protect the confidentiality, integrity, and availability of company assets by enforcing the principle of least privilege, ensuring accountability, and mitigating the risks associated with unauthorized access. Adherence to these controls is critical for maintaining regulatory compliance and safeguarding sensitive corporate and customer information. This policy, document version 3.4, is the authoritative standard for all access control activities within the organization.

1.2 Scope

This policy applies to all employees, contractors, vendors, temporary staff, and any third-party personnel (collectively referred to as "users") who require access to any company-owned or managed information system, network, application, or data repository. This scope includes, but is not limited to, cloud infrastructure environments (e.g., AWS, Azure, GCP), on-premises servers, SaaS applications, internal software development platforms, and databases. This policy governs the entire lifecycle of a user identity, from initial provisioning to final de-provisioning.

1.3 Technical Controls & Requirements

1.3.1 Authentication and Credential Management

All user access to information systems must be authenticated through a unique identifier assigned to a single individual. Sharing of user credentials is strictly prohibited.

Multi-Factor Authentication (MFA): The use of Multi-Factor Authentication is mandatory for all human users accessing any corporate system, without exception. This applies to console access, VPN access, and access to all critical SaaS applications. Approved MFA methods include FIDO2-compliant hardware security keys and Time-based One-Time Password (TOTP) applications. The use of SMS-based MFA is prohibited for administrative or privileged accounts.

Password Complexity: All passwords must meet a minimum complexity requirement as defined in the Password Construction Standard (DOC-SEC-401a).

1.3.2 Privileged Access and Authorization

Principle of Least Privilege: All users must be granted the minimum level of access and permissions necessary to perform their designated job functions. Permissions must be assigned based on job roles and responsibilities rather than direct user assignment where possible.

Root Account Prohibition: The use of the root account or equivalent superuser accounts (e.g., AWS root user, global administrator) for any routine operational or administrative task is strictly prohibited. All administrative functions must be performed using designated IAM roles or privileged accounts that are subject to heightened monitoring. The root account credentials must be vaulted, and access must require an explicit, time-bound approval from the Chief Information Security Officer (CISO).

Access Key Rotation: All programmatic access keys, API keys, service account credentials, and other long-lived secrets must be programmatically rotated on a mandatory cycle not to exceed ninety (90) days. Keys must be stored in an approved, centralized secrets management solution. Embedding credentials directly within source code or configuration files is a direct violation of this policy.

1.3.3 Account Lifecycle Management

User access provisioning and de-provisioning must be automated and directly linked to the Human Resources Information System (HRIS). Access must be granted on a user's official start date and must be revoked immediately upon termination or a change in role that obviates the need for such access. A formal process must exist for requesting, approving, and implementing access changes.

1.4 Auditing, Compliance, and Enforcement

All IAM events, including authentication attempts (successful and failed), privilege assignments, permission changes, and key generation events, must be logged to a central, tamper-evident security information and event management (SIEM) system. These audit logs must be retained for a minimum of 365 days for analysis and archived for a period of no less than seven (7) years.

The Compliance Officer, in conjunction with system owners, must conduct and formally attest to a quarterly access review for all users with privileged access to critical systems. Any discrepancies found during these reviews must be remediated within five (5) business days.

Failure to comply with this policy may result in disciplinary action, up to and including termination of employment or contract, and may be subject to legal action. Any request for an exception to this policy must be submitted in writing via the official exceptions process, detailing the business justification and compensating controls, and requires written approval from the Information Security Steering Committee.

2.0 Object Storage (S3)

2.0 Object Storage (S3)

2.1 Purpose

This policy chapter establishes the mandatory security controls, configurations, and operational procedures for the use of Amazon Web Services (AWS) Simple Storage Service (S3) and other compatible object storage solutions within the organization's technology infrastructure. The primary objective of this policy is to protect the confidentiality, integrity, and availability of all data stored within these systems. Adherence to these standards is critical for mitigating risks associated with data exposure, unauthorized access, data loss, and regulatory non-compliance. This document, version 3.1.4, provides the baseline security requirements that all personnel and automated systems must follow when creating, managing, or interacting with object storage resources.

2.2 Scope

This policy applies to all S3 buckets and stored objects across all company-managed AWS accounts, including but not limited to Production, Staging, Development, and Testing environments. It is binding for all full-time employees, part-time employees, contractors, consultants, and third-party vendors who are granted access to the organization's cloud environment. Furthermore, this policy extends to any automated system, application, or service that interacts with S3 resources, whether programmatically or through integrated services. All new and existing object storage buckets must be brought into compliance with this policy. Any deviations must be formally documented and approved through the official exception process overseen by the Information Security department.

2.3 Technical Controls

The following technical controls are mandatory and represent the minimum security baseline for all S3 resources. Additional controls may be required for buckets containing highly sensitive or regulated data, as determined by the data classification policy.

2.3.1 Access Control and Data Exposure Prevention

Public access to S3 buckets is a significant security risk and is strictly prohibited under all circumstances.

- The account-level "Block all public access" setting must be enabled and enforced across all AWS accounts.
- At the individual bucket level, the "Block all public access" configuration must be set to 'True'. This includes blocking public ACLs, public bucket policies, and any cross-account access that is not explicitly and formally approved.
- Access to S3 resources must be managed exclusively through AWS Identity and Access Management (IAM) principals (users, groups, and roles) and resource-based policies. The principle of least privilege must be strictly applied, granting only the minimum permissions necessary for a user or service to perform its designated function.

2.3.2 Data Encryption at Rest

All data stored within S3 buckets must be encrypted at rest to protect against unauthorized access to the underlying storage.

- It is mandatory for all S3 buckets to have default encryption enabled.
- The minimum required encryption standard is Server-Side Encryption with Amazon S3-Managed Keys (SSE-S3), which utilizes the AES-256 encryption algorithm.
- For buckets containing sensitive, financial, or personally identifiable information (PII), the use of Server-Side Encryption with AWS Key Management Service (SSE-KMS) is strongly recommended to provide an auditable trail of key usage and more granular access control over the encryption keys.

2.3.3 Data Durability and Recovery

To protect against accidental data deletion or corruption, specific data resiliency features must be enabled.

- For all S3 buckets designated as Production, it is mandatory that S3 Versioning is enabled. This feature preserves every version of every object, allowing for the recovery of objects from unintended user actions or application failures.
- Appropriate S3 Lifecycle policies should be configured to manage the retention and eventual deletion of non-current object versions to control storage costs, in accordance with the organization's data retention policy.

2.4 Auditing and Compliance

Continuous monitoring and regular audits are required to ensure ongoing compliance with this policy. The Governance, Risk, and Compliance (GRC) team, led by the Chief Compliance Officer, is responsible for this function.

- AWS CloudTrail must be enabled in all regions to log all S3 management and data events. These logs provide a critical audit trail for all activities performed against S3 resources.
- S3 Server Access Logging must be enabled for all Production buckets to provide detailed records of requests made to a bucket. All logs must be delivered to a separate, dedicated, and highly restricted S3 bucket.
- Automated compliance checks, using tools such as AWS Config, will be deployed to continuously monitor the configuration of S3 buckets against the controls defined in this policy. All findings and remediation actions will be documented in the master audit log (Reference: GRC-AUD-S3-FY24). Non-compliant resources will be flagged for immediate remediation by the responsible system owner. Failure to remediate within the specified timeframe will result in escalation to the Director of Security.

3.0 Compute Security (EC2)

3.0 Compute Security (EC2)

3.1 Purpose

This policy chapter defines the mandatory security requirements, standards, and controls for the provisioning, configuration, and management of all Amazon Web Services (AWS) Elastic Compute Cloud (EC2) instances. The primary objective is to protect the confidentiality, integrity, and availability of company data and systems hosted on the EC2 platform. Adherence to this policy is essential for maintaining our security posture and ensuring compliance with regulatory frameworks, including SOC 2 Type II and ISO/IEC 27001:2022. This document, Policy Version 4.1.2, supersedes all previous versions.

3.2 Scope

This policy applies to all AWS accounts owned or managed by the organization. It is applicable to all EC2 instances, Auto Scaling Groups, and related compute resources across all environments, including but not limited to production, staging, development, and testing. This policy must be followed by all full-time employees, part-time employees, contractors, and third-party personnel who have privileges to create, modify, or manage EC2 instances.

3.3 Policy Statements

3.3.1 Instance Hardening and Configuration

All EC2 instances must be launched exclusively from company-approved Amazon Machine Images (AMIs). The use of public, community, or unvetted AMIs is strictly prohibited. The official, mandated image is the "Company-CIS-AmazonLinux2-AMI-v3.1" or its most recent approved successor. All instances must be configured according to the principle of least privilege, with unnecessary software, services, and user accounts removed or disabled prior to deployment into a production environment.

3.3.2 Network Access Control

Network access to EC2 instances must be governed by a default-deny security posture. The following controls are mandatory and non-negotiable:

It is strictly prohibited for any Security Group attached to any EC2 instance to allow inbound traffic on TCP port 22 (SSH) from the public internet (CIDR block 0.0.0.0/0). This rule is absolute and has no exceptions.

All interactive administrative access to EC2 instances must be performed exclusively through a dedicated, hardened bastion host (also known as a jump box). The Security Group for the bastion host itself must be restricted to allow SSH access only from company-controlled IP address ranges.

All other network ports must be closed by default. Any required open ports must be explicitly justified for a specific business function, documented in a formal request, and approved by the Security Review Board. Security Groups must be configured to allow traffic only from specific, required source IP addresses or other Security Groups, avoiding broad or permissive rules.

3.3.3 Identity and Access Management

EC2 instances must not store static, long-lived AWS credentials (Access Key ID and Secret Access Key). All programmatic access to other AWS services from an instance must be managed through the use of an IAM Instance Profile. The IAM Role associated with the instance profile must be configured with the minimum necessary permissions required for the instance to perform its designated function.

3.3.4 Logging and Monitoring

The AWS CloudWatch agent must be installed and active on all EC2 instances to collect system-level logs, application logs, and performance metrics. All API activity related to EC2 services (e.g., RunInstances, StopInstances, CreateSecurityGroup) must be logged via AWS CloudTrail. CloudTrail logs must be enabled for all regions, centrally aggregated, and protected from modification. Log data from CloudWatch and CloudTrail must be retained for a minimum of 90 days in active storage and a minimum of 365 days in an archived, immutable state. AWS GuardDuty must be enabled in all accounts and regions to provide continuous threat detection.

3.3.5 Data Protection

All Elastic Block Store (EBS) volumes, whether root or data volumes, attached to EC2 instances must be encrypted at rest using AWS Key Management Service (KMS) with company-managed keys. All data transmitted to or from EC2 instances over public networks must be encrypted in transit using strong cryptographic protocols, specifically Transport Layer Security (TLS) version 1.2 or higher.

3.4 Enforcement and Auditing

Compliance with this policy is mandatory. The Information Security team will perform automated scans and manual audits on a quarterly basis to verify adherence to these controls. Any EC2 instance or Security Group found to be in violation of this policy will be flagged. A high-severity ticket will be automatically generated, and the resource owner will have 24 hours to remediate the finding. Failure to remediate a critical violation, such as public SSH access, will result in the immediate isolation or termination of the non-compliant resource. The designated Compliance Officer is responsible for reviewing audit reports and presenting findings to executive leadership. All policy exceptions must be formally documented, reviewed for risk, and approved by the Chief Information Security Officer for a limited duration.

4.0 Database Security (RDS)

4.0 Database Security (RDS)

4.1 Purpose

This policy chapter defines the mandatory security controls, standards, and procedures for the configuration, management, and use of Amazon Web Services (AWS) Relational Database Service (RDS) instances. The primary objective of this policy is to protect the confidentiality, integrity, and availability of all data stored within company-managed RDS databases. Adherence to these controls is essential to mitigate risks of unauthorized access, data breaches, and operational disruptions, and to ensure compliance with relevant regulatory and contractual obligations.

4.2 Scope

This policy applies to all AWS RDS instances, including all database engines (e.g., PostgreSQL, MySQL, MariaDB, SQL Server, Oracle), across all company-managed AWS accounts and environments (production, staging, development, and testing). This policy is binding for all employees, contractors, and third-party vendors who are involved in the provisioning, administration, or use of these database services. Any deviation from this policy requires a formal, documented exception request approved by the Chief Information Security Officer (CISO).

4.3 Policy Statements

4.3.1 Network Access and Connectivity

All RDS database instances must be deployed within a designated Virtual Private Cloud (VPC) and isolated within private subnets. It is strictly prohibited for any RDS instance to be configured with the 'PubliclyAccessible' flag set to 'True'. Network access to RDS instances must be restricted by utilizing security groups that adhere to the principle of least privilege. Security group rules must only allow traffic from specific, authorized application servers or bastion hosts on designated ports. Any request for broader access must be formally justified and approved by the Security Team.

4.3.2 Data Encryption

Encryption of data at rest is mandatory for all RDS instances. All databases must be configured with encryption enabled at the time of creation, utilizing AWS Key Management Service (KMS) with a customer-managed key (CMK). The encryption algorithm must be AES-256. Encryption of data in transit is also mandatory. All applications connecting to RDS instances must be configured to use a secure transport protocol, specifically TLS version 1.2 or higher. Database parameter groups must be configured to enforce SSL/TLS connections (e.g., `rds.force_ssl=1` for PostgreSQL).

4.3.3 Authentication and Access Control

The use of the master database user account for routine application or user access is strictly prohibited. The master account shall only be used for initial setup and emergency administrative tasks. Whenever supported by the database engine, AWS IAM Database Authentication must be enabled and utilized as the primary method for authenticating user and application connections. This provides centralized access control through IAM policies. For any legacy systems requiring native database passwords, these passwords must adhere to the corporate password complexity policy and be rotated at least every 90 days.

4.3.4 Backup and Recovery

Automated backups for all production RDS instances shall be enabled with a mandatory minimum retention period of thirty (30) days. This ensures adequate data is available for operational recovery and forensic investigation. Point-in-time recovery (PITR) must be enabled for all production databases with a backup window configured during off-peak hours. All production RDS instances must be deployed in a Multi-AZ configuration to ensure high availability and automatic failover. The Database Administration team must conduct and document disaster recovery tests on a semi-annual basis to validate the integrity and recoverability of backups.

4.3.5 Logging and Monitoring

Comprehensive logging must be enabled for all RDS instances. The following logs are mandatory and must be configured for export to Amazon CloudWatch Logs: the database error log, the general/query log, the slow query log, and the audit log. From CloudWatch Logs, these logs shall be streamed to the organization's central Security Information and Event Management (SIEM) platform for real-time monitoring, correlation, and long-term retention. The Security Operations team is responsible for configuring alerts for suspicious activities, including but not limited to, repeated failed login attempts, privilege escalation events, and significant changes to database schemas.

4.3.6 Configuration and Patch Management

All RDS instances must run on approved, recent, and stable versions of their respective database engines. As of this policy's issuance, minimum versions are PostgreSQL 14.5 and MySQL 8.0.30. The "Auto minor version upgrade" feature must be enabled to ensure that security patches are applied in a timely manner. A formal process for planning, testing, and applying major version upgrades must be followed within 180 days of a new stable version release to mitigate risks associated with end-of-life software.

4.4 Roles and Responsibilities

The Chief Information Security Officer (CISO) is ultimately responsible for this policy.

Database Administrators (DBAs) are responsible for implementing and maintaining the technical controls detailed herein.

The Security Team is responsible for auditing compliance, monitoring for threats, and managing IAM database access policies.

System Owners are responsible for classifying the data within their databases and approving access requests in accordance with the principle of least privilege.

4.5 Compliance and Enforcement

Compliance with this Database Security (RDS) policy is mandatory. The internal audit team will perform periodic reviews of all RDS configurations to ensure adherence to these standards. Any identified instance of non-compliance will be documented and reported to the responsible team lead and the CISO. Failure to comply with this policy may result in disciplinary action, up to and including termination of employment or contract, in accordance with established human resources procedures. All policy exceptions must be formally documented, include a risk assessment, and be approved in writing by the CISO and the Compliance Review Board.

5.0 Network Security (VPC)

5.0 Network Security (VPC)

5.1 Purpose

This policy chapter defines the mandatory standards and controls for securing the network infrastructure within the company's cloud environments, specifically concerning the Virtual Private Cloud (VPC). The primary objective of this policy is to establish a secure network perimeter, enforce the principle of least privilege for network traffic, and ensure comprehensive visibility into all network activity. Adherence to this policy is critical for protecting the confidentiality, integrity, and availability of company data, systems, and services, and for meeting our contractual and regulatory compliance obligations, including but not limited to PCI DSS and SOC 2.

5.2 Scope

This policy applies to all Virtual Private Clouds (VPCs) and their associated components provisioned in the company's cloud accounts, including all production, staging, development, and testing environments. The scope encompasses all network elements, including but not limited to: Subnets, Route Tables, Internet Gateways, NAT Gateways, Security Groups, Network Access Control Lists (NACLs), VPC Endpoints, and VPC Peering connections. This policy is binding for all full-time employees, part-time employees, contractors, and third-party vendors who are involved in the design, implementation, management, or auditing of the company's cloud network infrastructure.

5.3 Technical Controls

5.3.1 Security Group Configuration

Security Groups function as stateful, host-level firewalls and represent a primary line of defense. Their configuration must be strictly controlled.

It is mandatory that the default Security Group for any newly created VPC be immediately modified to deny all inbound and all outbound traffic. The default "allow all" egress rule is strictly prohibited and must be removed upon VPC creation. This "deny-all by default" stance ensures that no resource is inadvertently exposed.

All custom Security Groups must be configured based on the principle of least privilege. Inbound and outbound rules must be specific, explicit, and justifiable. The use of overly permissive source or destination IP ranges, such as "0.0.0.0/0" or ":::/0", for inbound traffic to sensitive management ports (e.g., TCP/22, TCP/3389) is strictly prohibited. Any proposed use of "0.0.0.0/0" for any other service requires a formal risk assessment and documented, time-bound approval from the Chief Information Security Officer (CISO). Each rule within a Security Group must be accompanied by a description tag that references a valid ticket number from the IT Service Management system, providing a clear audit trail for its business justification.

5.3.2 VPC Flow Log Monitoring

Comprehensive network visibility is a mandatory requirement for security monitoring and incident response.

To this end, VPC Flow Logs must be enabled for all VPCs across all company cloud accounts without exception. This control is non-negotiable and will be enforced through automated

configuration management checks. The log record format must be configured to use the latest stable version, currently defined as Custom Format Version 5.1, which includes fields for packet-level source and destination, TCP flags, and VPC endpoint IDs.

All generated Flow Logs must be centrally aggregated and ingested into the corporate Security Information and Event Management (SIEM) platform for continuous monitoring, correlation, and alerting. Logs must be retained for a minimum period of 365 days. A minimum of 90 days of log data must be kept in online, "hot" storage for immediate analysis, with the remaining 275 days stored in immutable, archival "cold" storage. The Security Operations team shall review anomalous traffic patterns reported by the SIEM on a daily basis.

5.3.3 Network Segmentation

Logical segmentation and isolation of network resources are required to limit the potential impact of a security breach. All VPCs must be designed with a multi-tiered architecture using a combination of public and private subnets. Production systems, especially those processing or storing sensitive data, must be deployed within private subnets that have no direct route to an Internet Gateway. Outbound internet connectivity from resources in private subnets must be routed exclusively through a managed NAT Gateway or an actively monitored egress filtering proxy solution. Network Access Control Lists (NACLs) shall be employed as a secondary, stateless defense layer to enforce broad subnet-level restrictions, such as denying traffic from known malicious IP address blocks maintained by the Threat Intelligence team.

5.4 Roles and Responsibilities

The Cloud Engineering team is responsible for the implementation and maintenance of all VPC components in strict accordance with this policy.

The Security Operations team is responsible for the continuous monitoring of VPC Flow Logs and for responding to any security alerts or incidents identified.

The Compliance Officer, Jane Doe (ID 78-4B), or their delegate, is responsible for conducting quarterly audits of all VPC configurations to ensure and attest to full compliance with this policy. Audit log evidence, including configuration snapshots and Flow Log settings, must be provided to the Compliance Officer within five business days of a formal request.

5.5 Policy Enforcement and Exceptions

Compliance with this policy will be enforced through automated configuration scanning tools, which will report any deviation to the CISO's office. Non-compliance may result in the immediate revocation of access privileges and, for employees, may lead to disciplinary action up to and including termination of employment.

Any request for an exception to this policy must be submitted through the formal risk acceptance process. The request must include a detailed business justification, a thorough risk analysis, and proposed compensating controls. All exceptions require written approval from both the Director of Infrastructure and the Chief Information Security Officer and will be documented and reviewed on a semi-annual basis.